

AegisCare HMS — Developer Self-Attestation

System	AegisCare HMS (LabTrack v5.5 codebase)
Repository	fmurage6331-dev/confit-core
Branch / commit basis	arena/01a037b8-confit-core (based on 7b59358)
Date	2026-08-25
Prepared by	Francis Muhoro / AegisCare development team
Document type	Developer self-attestation for DHA certification readiness (Form HMIS 4 pathway)
Related docs	docs/dha-compliance-assessment.md, docs/certification/DOC-1 ... DOC-8

Developer Declaration

This self-attestation is a **voluntary, honest pre-submission review** of AegisCare HMS against the Digital Health Agency (DHA) certification expectations, the Kenya Digital Health Act 2023, the Digital Health (Data Exchange Component) Regulations 2025, the Digital Health (Health Information Management Procedures) Regulations 2025, the Kenya eClaims FHIR Implementation Guide, the Kenya Health Information Systems Interoperability Framework (KHISIF), the Kenya Data Protection Act, 2019, and the Social Health Insurance Act, 2023.

I/we declare that:

- The information in this attestation reflects the actual state of the code and infrastructure at the date above.
- Known gaps are disclosed below rather than hidden.
- No regulatory certification is claimed on the basis of this document alone.
- DHA certification, ODPC registration, healthcare-facility licensing, and clinical approval remain separate responsibilities for the deploying facility / organization.

AI Tool Usage Declaration

Claude (Anthropic) — Primary Development Assistant

Claude was used throughout the AegisCare HMS development for code generation, code review, documentation drafting, SQL review, data-model design, and FHIR/SHA structure drafts. All generated code was reviewed, tested, and adapted by the developer before inclusion.

Arena AI — Autonomous Agent

An autonomous Arena AI agent was used in this session to implement the SHA claims state-machine UI, KMHFL sync, DSAR export, 72hr SLA timer, Supabase type updates, and draft compliance docs. The agent operated under explicit instructions to:

- Read existing files before changing them.

- Not modify protected files (`src/routes/moh.*` , `src/lib/moh-reports.ts` , `src/components/moh/*` , `patches/` , and `src/routes/inpatient.tsx` except where explicitly authorized).
 - Run ESLint/Prettier and TypeScript checks before committing.
 - Commit only to the session branch `arena/01a037b8-confit-core` .
 - Give Francis exact SQL rather than running SQL directly.
-

What AI Was Used For

AI was used for/assisted with:

1. **Schema & SQL review** — reviewing existing `sha_claims` , `sha_claim_items` , `build_fhir_claim()` , triggers, audit triggers, and generated Supabase types.
 2. **SHA claims state machine** — Admin → Claims queue tab listing `sha_claims_aging` , color-coded status badges, Submit / Approve / Reject / Record Payment / Resubmit buttons, `sha_claim_status_history` writes, age/missing-data/resubmission badges, PHF banner.
 3. **KMHFL sync** — "Sync from KMHFL" button in facility settings calling the public KMHFR API.
 4. **DSAR export** — admin-only patient data export as JSON with audit logging.
 5. **Preauth SLA UI** — 72-hour SLA timer and SHA eligibility placeholder in the insurance dialog.
 6. **Docs** — DHA compliance assessment and this self-attestation draft.
 7. **SQL linting** — ensuring provided SQL is idempotent/re-runnable for Francis to apply.
-

What Developer Did Without AI

The developer (Francis Muhoro / AegisCare team) performed (at minimum):

- Provisioning and configuration of the Supabase project, OAuth, Supabase edge functions, and deployment.
 - Data-model decisions and approval of SQL before execution.
 - Manual verification/execution of schema changes in the project database.
 - Live facility/account and SHA-provider setup where applicable.
 - Business, clinical, and facility-level requirements definition.
 - Selection and validation of clinical terminology mappings (ICD-11, MOH indicators).
 - HIPAA/ODPC/clinical-safety judgment calls where AI output was judged insufficient.
 - Any deployment and release approval.
-

AI Output Review Process

For AI-generated code in this session:

1. `npx eslint <file> --fix` was run.
2. `npx eslint <file> --max-warnings=N` was run (0 warnings except `rooms.$id.tsx` , which is allowed 4 existing warnings).
3. `npx tsc --noEmit` was run; the only reported errors are pre-existing errors in auto-generated MCP route files (`src/routes/[.mcp]/*` , `src/routes/mcp.ts` , `src/routes/[.well-known]/oauth-protected-resource.ts`).
4. Changes were reviewed via `git diff` before committing.
5. SQL was not run directly by the agent; exact SQL was provided to Francis and applied by the developer.

6. Dangerous/invasive files were not touched.
7. The session work was committed only to `arena/01a037b8-confit-core`.

Known limitation: `src/integrations/supabase/types.ts` was updated manually because the Supabase CLI had no access token in the sandbox. It should be regenerated from the live project before production to confirm exact generated output.

Known Compliance Gaps

These are acknowledged gaps. They are intentionally not hidden.

1. **SHA API credentials pending** — no live SHA eligibility, preauth, claim submission, or ClaimResponse ingestion until credentials are configured.
2. **DHA credentials pending** — no AfyaLink HIE access/JWT/OAuth billing/test onboarding.
3. **Biometric verification not built** — patient identity relies on manual/national-ID fields; DHA's Afya Yangu biometric/self-registration path is not implemented.
4. **Data hosted outside Kenya** — current hosting arrangement is not confirmed to be in-Kenya; cross-border transfer safeguards (SCCs/TIA) are incomplete.
5. **ODPC registration pending** — no confirmed ODPC controller/processor certificate and no DPO appointment.
6. **DHA facility registration pending** — no confirmed DHA certification application, ESB onboarding, or facility/DHA certificate of compliance.
7. **AT SMS Sender ID pending** — the SMS/OTP delivery path is not production-verified with a registered Kenyan messaging Sender ID.
8. **Penetration test not done** — no third-party penetration test report on the deployment.
9. **MFA not implemented** — login currently does not enforce multi-factor authentication.
10. **Supabase cron pauses on free tier** — background automation (billing accrual, dispatcher) may not run reliably on a free-tier Supabase plan.

Additional gaps:

- PHC/PHF zero total amount assertion not enforced in claim data yet.
- Full SHA Claim message Bundle (Organization + Patient + Coverage + Claim) not assembled with DHA profile meta and `servedPeriod`.
- Kenya eClaims FHIR profile conformance not validated.
- 20-year audit/health-data retention not yet enforced as a lifecycle.
- 48-hour DHA / 72-hour ODPC breach notification runbook not implemented.
- DSAR is implemented as an export but no systematic erasure request workflow.

Security Self-Assessment

Control	Status	Notes
Authentication	⚠ PARTIAL	Supabase Auth implemented; MFA not enforced
Authorization / RBAC	✅ COMPLIANT	roles + PermGuard, admin-only surfaces
Row-level security	✅ COMPLIANT	enabled on clinical and SHA tables
Audit logging	⚠ PARTIAL	<code>audit_trigger_fn</code> , audit log UI; immutability/20-year retention to be proven

Consent / OTP	⚠ PARTIAL	local OTP consent; live SHA consent token flow pending
Access to sensitive data	✅ COMPLIANT	role-gated patient/encounter views, break-glass logging
Data encryption at rest/transit	⚠ PARTIAL	Supabase/TLS assumed; not independently verified
Vulnerability / PEN test	🔴 GAP	not performed
Secrets management	⚠ PARTIAL	env-based secrets; not verified against a dedicated secrets manager
Backup / recovery	⚠ PARTIAL	policy exists; tested restore not demonstrated

Clinical Safety Declaration

AegisCare HMS is intended to support clinical workflow **but is not a substitute for clinical judgment**. No warranty of clinical safety is made by this self-attestation. Before use:

- Clinical workflows must be validated by a qualified clinical safety officer (or equivalent).
- Any diagnostic or treatment decision supported by the system must be reviewed by a licensed clinician.
- The system must not be used for emergency clinical decisions without appropriate clinical oversight.
- Medicare/SHA reimbursement claims generated by the system must be reviewed by the facility's billing/claims team prior to submission.

Intellectual Property Declaration

- The AegisCare HMS codebase, including the current branch work, is the property of AegisCare / the repository owner.
- No third-party proprietary code was knowingly copied into the codebase.
- Open-source packages used by the system are listed in `package.json` / `bun.lock` / `package-lock.json` and retain their respective licenses.
- The AI tooling used did not vest copyright in the developer's code.
- Regulatory/documentation content in `docs/` is drafted for the project owner's use.

Formal Attestation Signature

Attestation	I/we hereby attest that the development work, code, SQL, and documentation described in this self-attestation were produced as described, and that known gaps are honestly reflected above.
Name	Francis Muhoro
Role	Developer / System Owner (AegisCare)
Date	2026-08-25

Signature*(electronic signature pending)*

This is a developer's self-attestation, not a DHA/ODPC certificate. Final compliance determination rests with the DHA certification framework, ODPC registration/certification, and the deploying facility's governance.